

Outlining a Model Integrating Risk Management and Agile Software Development

Jaana Nyfjord and Mira Kajko-Mattsson
 Department of Computer and Systems Sciences
 Stockholm University/KTH
 SE-164 40 Kista SWEDEN
 {jaana}{mira}@dsv.su.se

Abstract—Previous studies show that the agile development models implement very few risk management practices. In this paper, we present and evaluate a model integrating the risk management and agile processes. The results show that the model provides a valid solution to address the lack of risk management, however, only in certain types of agile projects.

Keywords- *software process, evaluation*

I. INTRODUCTION

Controlling risks improves essential software development features such as product quality, planning precision and cost-efficiency [5]. For this reason, the inclusion of risk management in software development is an important factor to consider if one wishes to achieve project success [5]. Unfortunately, many software development models, both the traditional and agile ones, are not well aligned with the risk management process practices [3] [14].

In our research, we have addressed this by outlining a model specifically aimed at aligning the agile process model with risk management. The model consists of two parts, (a) an integration model providing guidance for integrating the risk management and agile processes, and (b) an integrated model that places risk management in the agile process.

In this paper, we present and evaluate the model. We do this by interviewing ten agile practitioners in the Swedish software industry. Our goal is to determine whether the proposed model is a valid solution to address the lack of risk management in agile development.

This paper is structured as follows. Section II presents our research method. Section III describes the integration model. Section IV provides an overview of the integrated model and a practical example based on an industrial case. Section V presents the results of the evaluation in industry. Finally, conclusions and suggestions for future research are presented in Sections VI and VII.

II. RESEARCH METHOD

This section describes our research method. Section II.A presents the research steps. Section II.B describes the requirements against which the model is evaluated. Section II.C presents the studied organization and the interviewees.

A. Research Steps

As the first two steps, we studied the status of the agile and risk management processes in industry. It resulted in a synthesized agile and a synthesized risk management process model, respectively. They are presented in Figures 1 and 2 and reported in [8] [9] and [10]. In this paper, they constitute a basis for outlining the integrated model.

In the third step, we studied various agile development process scenarios in which risk management was executed. We did it within one software organization, SVT-I, to be described in Section II.C. The goal was to study risk management in the context of an agile process and to identify integration points between the two processes. Using these integration points, we created a simple integration model, which we then used for outlining the integrated model. The models are described in Sections III and IV, respectively.

- In the fourth step, the models were presented to and evaluated by ten agile practitioners representing various companies in Sweden. Their profiles are described in Section II.C. The goal of the evaluation was to validate the proposed models. We did this by evaluating them against a set of requirements that they were expected to fulfill. The evaluation was conducted in the form of in-depth interviews. The requirements and the questionnaire are described in Section II.B.

Finally, in the fifth step, we analyzed the evaluation results. It resulted in an evaluation of the validity of the proposed model but also suggestions for improvements. We present and discuss the results in Section V and VI.

B. Evaluation Requirements and Questionnaire

To be able to evaluate our models, we created a set of requirements. These requirements concerned the usability of the integration and integrated models, and the aspect of agility. They were the following:

- The integration model should provide software organizations practical guidance on how to integrate their risk management and agile development processes.
- The integrated model should provide a reference model

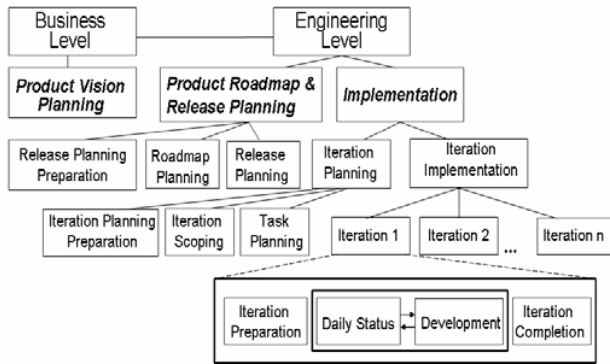


Figure 1. Synthesized agile process model [8][9]

for software organizations to examine their risk management practice

- The solution should provide guidance for reasoning about agility with respect to the need of risk management.

Using these requirements, we created an open-ended and semi-structured questionnaire consisting of 30 questions altogether. Due to space restrictions, we cannot present it in this paper. However, it may be provided on request.

C. Profile of SVT-I and the interviewees

SVT-I (Svensk Television-Interactive) is a Swedish software organization that develops a web-based system for broadcasting TV programs on the Internet. It has 35 employees. The studied team consisted of eight people; a product owner, a scrum master and six developers. The development process was Scrum [13] combined with the practices of *Informative Workspace*, *Stories*, *Incremental Development*, *Test-Driven Development*, and *Pair Programming* [1]. In our evaluation, we interviewed ten practitioners representing various organizations in the Swedish software industry using agile processes. The group included the following roles: consultant (4), developer (2), scrum master (2), product owner (1), and CEO (1).

III. INTEGRATION MODEL

There is no general method or process for the integration of agile and risk management processes [1]. For this reason, we needed to create our own integration model.

By studying various agile process scenarios in which risk management was executed at SVT-I, we were able to identify four basic integration points between the two processes. Using them, we created a simple integration model consisting of four basic integration points. We call them (1) *Organizational Levels and Process Phases*, (2) *Roles and Responsibilities*, (3) *Communication Channels*, and (4) *Process Aspects*. Below, we briefly describe and motivate them:

- *Organizational Levels and Process Phases*: A critical integration point involves the identification of *when* and *where* risk management takes place in the development process. The agile development process consists of several



Figure 2. Synthesized risk management model [10]

phases and it spans over several organizational levels. By finding out where risk management occurs clarifies the various points of integration between the two processes.

- *Roles and Responsibilities*: In the context of process integration, roles comprise a primary crossing point for the exchange of information between the two processes. According to standard risk management practice, risks should also be owned by various roles to ensure that they are effectively managed [12]. Hence, one needs to define appropriate roles and their responsibilities.

- *Communication Channels*: Agile development and risk management are communication intensive processes. The communication gets intensified if risks are managed across the whole organization and several processes and process phases. To achieve effective communication, one needs to designate appropriate communication channels. They integrate the processes and their phases by specifying the flow of communication on an organization-wide level.

- *Process Aspects*: Processes are variable and dynamic. Their instances vary due to many different aspects affecting the process design. In this integration model, they are covered by some fundamental aspects of risk management as identified in [7]. Each of these aspects determines the magnitude of risk management required within the integrated process, thus aiding in adapting an instance of an integrated model to the specific situation at hand. The following aspects should be considered:

- *Risk definition*: constitutes a control that there exists a comprehensible risk definition to facilitate the communication of risks within the organization.
- *Risk assessment*: defines a control that there are guidelines for assessing risks effectively.
- *Software lifecycle*: defines a control for designating adequate risk management activities according to the varying needs of different software lifecycle phases.
- *Stakeholders, roles and responsibilities*: defines a control for streamlining the degree of involvement of various stakeholders, roles and their responsibilities as determined by factors such as project size and risk profile.
- *Supporting tools/repositories*: constitutes a control for considering the need of tools to support effective communication of risks and their management.
- *Template*: constitutes a control for identifying the degree of formality of templates needed for recording risks and their management effectively.
- *Product status*: defines a control for determining the amount of risk management needed with respect to the product quality, business value and life expectancy.

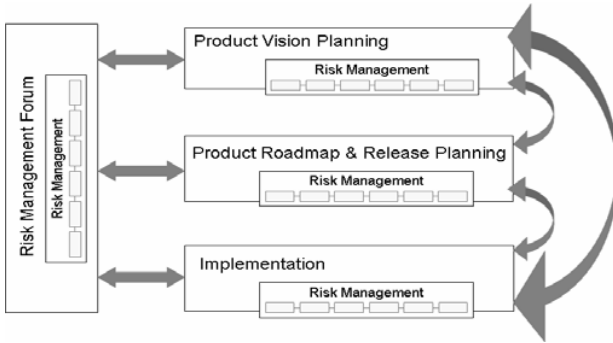


Figure 3. Overview of integrated model

- *Environment*: constitutes a control for considering how to adopt risk management to the project's cultural, social, political and physical context.
- *Organization*: defines a control for considering organizational aspects such as people's attitudes towards risks, organizational maturity, competency and training and their impact on a risk management program.
- *Measures*: constitutes a control for determining the need for integrating the risk management process with other organizational processes, such as measurement processes, to provide useful information and feedback to the organization.

IV. INTEGRATED MODEL

In this section, we describe the integrated model. We start with a model outline. We then describe its real-life scenario at SVT-I.

A. Integrated Model

The integrated model manages all risks encountered on an organization-wide basis. As depicted in Figure 3, the agile process covers three main development phases, *Product Vision Planning*, *Product Roadmap and Release Planning*, and *Implementation* [8][9].

Most of the risks undergo a complete risk management process within a phase. The ones that are not mitigated may have to be transferred to the next phase, and/or get reported to the *Risk Management Forum (RMF)*. The forum is a function for coordinating risk management across the organization. It manages any risks that will have to be promptly disseminated, for instance risks concerning several teams. It consists of a cross-functional group represented by the roles responsible for or concerned with or capable of managing these kinds of organizations-wide risks.

In the following, we provide a brief overview of the integrated model. It is described according to the integration model and its four integration points, (1) *Process Phases and Organizational Levels*, (2) *Roles and Responsibilities*, (3) *Communication Channels*, and (4) *Process Aspects*.

1) Organizational Levels and Process Phases

The integrated model covers the entire agile development process. This involves integration of risk management on two organizational levels: the *Business* and *Engineering*

levels [8][9]. As depicted in Figure 1, the *Business Level* consists of the *Product Vision Planning* phase. The *Engineering Level* consists of *Product Roadmap and Release Planning* and *Implementation*.

- *Product Vision Planning*: This phase involves creating a product vision plan guiding the work carried out in subsequent planning, decision making, and development [13]. Risk management within this phase mainly concerns the identification and analysis of business related risks, such as budget and resource risks.
- *Product Roadmap and Release Planning*: Here, one first creates a high-level roadmap plan for the product releases which one then regularly revisits before the start of each new release [2]. The risk management in the *Product Roadmap and Release Planning* phase comprises risk identification, analysis and action planning. It involves both business and technical risks.
- *Implementation*: Here, the team, product management and other stakeholders plan the work to be conducted in the coming iteration. The plan is then executed to deliver an increment of working product functionality [2]. Risk management in this phase primarily covers the monitoring and controlling of the risks that have been transferred to this phase from previous development phases. New risks are also continuously identified, analyzed and planned for during this phase. Risks are mainly of technical character.

2) Roles and Responsibilities

In the integrated model, we have identified several roles having various responsibilities with respect to risk management and its communication. Generally, however, the risks are owned by the roles in the phase where the risk is originally identified. The roles and responsibilities are:

- *RMF Members* own all the organization-wide risks. Their main task is to supervise and coordinate all the organization-wide risks and make decisions on them. However, they may delegate their management to other roles either within the *Business* or *Engineering* levels or both.
- *Business Manager* is responsible for managing risks at the *Business Level*. This role owns all the risks relevant for this level. However, he may delegate their management to the roles in the *Product Roadmap and Release Planning* or *Implementation* phase. The choice depends on the character of the risk and where in the organization it is most adequately managed. Still however, he keeps the risk ownership till the delegated risks get mitigated.
- *Product Manager* is responsible for all the risks managed in the *Product Roadmap and Release Planning* phase. This role owns all the risks relevant for this level. However, similarly to the business manager, he may delegate their management to other roles in the organization, if needed. He still keeps the risk ownership till the risks get mitigated.
- *Team Leader* and *Team Members* are responsible for managing risks within the *Implementation* phase. The team leader supervises the risk management. Usually, team

members own the risks that concern the development tasks assigned to them. However, the team may also decide to delegate the risks to others in the organization depending on the risk and its management needs.

3) Communication Channels

An effective management of organization-wide risks rests on how risks are communicated within an organization. This is because, in the integrated model, risk management takes place throughout the entire development process. Hence, to warrant effective information flow, one needs define communication channels. As depicted by the double-edged arrows in Figure 3, the integrated model identifies six main two-way *Communication Channels*. The difference between them concerns the different roles in each phase who act as the main senders and receivers of risk information. The communication channels are: (1) *Product Vision Planning - RMF*, (2) *Product Vision Planning - Product Roadmap and Release Planning*, (3) *Product Roadmap and Release Planning - RMF*, (4) *Product Roadmap and Release Planning - Implementation*, (5) *Product Vision Planning - Implementation*, and (6) *Implementation - RMF*.

4) Process Aspects

Our study at SVT-I has helped us identify the impact of *Process Aspects* on the integrated model. This impact is materialized in the following process design guidance:

- *Risk definition is a main prerequisite for identifying risks and to communicate them effectively*: The definition of risk is of high relevance for an effective communication on risk and hence for making decisions on when to perform risk management in software development.
- *Risk assessment results identify pertinent actions for performing risk-driven development*: The risk classification and assessment techniques are important for knowing when and how to manage risks effectively in subsequent process phases. Hence, guidelines for assessing risks are needed.
- *The product's software lifecycle stage aids in designating appropriate risk management actions*: The portfolio of risk types and risk management activities differs considerably depending on whether a project concerns new development or maintenance of a legacy system. Hence, the process is adapted to the prevailing risk types and their prioritization.
- *Designation of and coverage of stakeholders, roles and responsibilities are determined by factors such as project risk profile, type and size*: The coverage of stakeholder roles and the degree of their involvement depends on the type of project and its size, risk complexity, scope and criticality.
- *The use of supporting tools and repositories are determined by factors such as project risk profile, type, size and team distribution*: The relevance of tools depends on the organization size, project needs and risk profile.
- *The formality of recording risk information varies by risk profile, project type, size, and team distribution*: Templates provide relevant support for describing and communicating risks. However, the extent of using them and the degree of

Table 1. Mapping of risk management in agile phases

<i>Risk mgmt</i> <i>Agile</i>	Risk identification	Risk analysis	Risk mgmt planning	Risk mon. & control	Risk sign-off	Risk post-mortem
Product vision planning	●	●				
Product roadmap & release	●	●	●			
Implementation	●	●	●	●	●	●

their formality varies with respect to project type, size, team distribution and risk severity.

- *Product status, life expectancy and business value help determining the amount of risk management process needed*: Risks and their criticality vary by product status, life expectancy and business value. Hence, the amount of attention put into the risk management process varies.
- *Environment and the project's physical context determine the formality of the risk management process*: Large organizations generally need a more conventional risk management process due to the need of more coordination.
- *Organizational maturity and training aids in adopting a risk management program successfully*: Organizational maturity, such as people's attitude towards risks, competency, and capability to perform risk management are of relevance for successful adoption of risk management.
- *Software development need be integrated with other organizational processes*: The development and risk management processes need be integrated to provide useful feedback to the organization, especially in larger organizations. Hence, one needs guidelines for making such integration explicit.

B. Integrated Model at SVT-I

At SVT-I, all organization-wide risks are managed by the *Architectural Forum (AF)*. The *AF* corresponds to the *RMF* in our model. Risk management comprises a critical part of its function. The purpose is to effectively coordinate risks that need attention on an organization-wide basis. For instance, the *AF* may coordinate the management of a critical technical risk identified in the *Implementation* phase having impact on the release schedule, and consequently, on the planned system integration and delivery.

The *AF* consists of a group of roles that are represented by key personnel, such as business and product managers, team leaders, architects, and customers. They meet regularly on both an incident-driven and periodic basis (every three weeks).

The *AF* has its own risk management process. Some risks may be managed in their entirety within the forum. Some other risks may have to be delegated and/or managed in co-operation with the appropriate role(s) active in the phase relevant for the risk. However, the *AF* keeps the principal ownership of these risks throughout their whole

management. It has the utmost authority to sign them off.

Regarding risk management in the *Product Vision Planning* phase, it mainly concerns business related risks. It is managed by business management. As depicted in Table 1, the risks that are not fully mitigated at this level undergo at least the first two risk management phases, *Risk Identification* and *Risk Analysis*. These risks will be further analyzed and managed in the subsequent phases. Some of them, however, may be reported to the *AF*, who also re-analyses them to determine further measures.

The risks managed in the *Product Roadmap and Release Planning* phase are owned and managed by the product manager. Initially, they comprise business risks.

As the high-level product vision plan evolves into the product roadmap plan and finally into more detailed release plans, new risks may be identified, analyzed and planned for in this phase. The result is materialized in a risk list and a risk management plan, supervised by the product manager. At this stage, risks are still mainly of business character but technical risks may be identified as well. The risks are delegated to the appropriate candidates within the organization, if needed. However, the product manager still keeps the main ownership of the risks and is the only authority to sign-off the mitigated risks.

The product manager may also transfer the identified risks to the *AF* for further action. These risks may concern schedule risks that should be further coordinated and communicated to others in the organization. The risks of technical nature concerning the implementation of certain system functionality get transferred to the *Implementation* phase, where they are further analyzed, planned for, and monitored and controlled by the team and its members.

As presented in Table 1, the mapping of risk management in the agile process shows that the risks that cannot be mitigated in the *Product Roadmap Planning* or *Release Planning* sub-phases mainly undergo *Risk Identification* and *Risk Analysis*. In addition, the *Release Planning* phase involves *Risk Management Planning* for determining the actions needed to mitigate the identified risks for that release.

The *Implementation* phase is performed by a team leader together with team members. We have identified a pattern of managing risks within this phase. As depicted in Figure 4, it is as follows: *Iteration Planning* mainly involves *Risk Identification*, *Risk Analysis* and *Risk Management Planning*. Risks are mainly monitored and controlled during *Daily Status* and *Development* in the *Iteration Implementation* phase. New risks may also be identified during *Daily Status*, which are then analyzed and planned for. The *Iteration Completion* phase involves *Risk Sign-Off* and *Risk Post-Mortem Analysis*. Below, we elaborate on this.

Risk management is continuously performed within an iteration. Risk monitoring, control and treatment are mainly

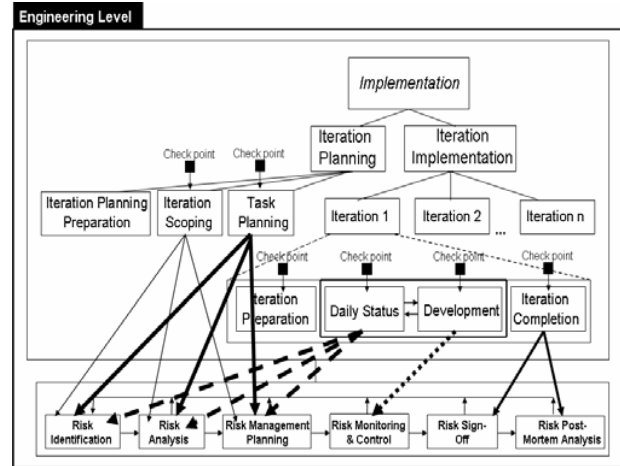


Figure 4. Mapping of risk management in the agile *Implementation* phase

conducted within the development activities. Risk monitoring, however, takes place via the so-called “checkpoints”, where one actively inspects the risk status. As illustrated in Figure 4, the main checkpoints are (1) *Iteration Scoping*, (2) *Task Planning*, (3) *Daily Status*, (4) *Development* and (5) *Iteration Completion*.

During the *Iteration Scoping* and *Task Planning* sub-phases, one studies the known risks and identifies the new ones. One then analyzes them, and makes appropriate decisions. Some of the risks may already have become mitigated during the *Iteration Planning*. In this case, they are checked off from the risk list. For the remaining risks, one creates risk action plans.

Usually, one risk concerns one task or feature to be implemented. Hence, the risk ownership is automatically assigned to each programmer or programmer pair being responsible for that task. In addition, the team leader has a supervising ownership for all the identified risks. The team leader has also the utmost responsibility for the remaining risks that cannot be assigned to the team members.

During the iteration, risks are continuously monitored in the *Daily Status* phase. Here, one discusses the known risks and identifies the new ones. Some minor risks may even be analyzed and planned for, or even mitigated, during a meeting. For more serious risks, however, one arranges special sessions or new meetings, during which one analyzes risks and determines further measures. Between the daily meetings, the risks are monitored and controlled by the risk owners in the *Development* phase. They are also continuously supervised by the team leader.

In the final checkpoint, that is, the *Iteration Completion* phase, one evaluates the product, the process and the risks. Regarding the risks, one goes through the list of all the risks and analyses how they have been monitored and controlled, whether they have been mitigated, and one identifies the effects of the risk management process. In this phase, all the

mitigated risks get signed off and removed from the risk list. The business risks get signed off by the product owner, whereas all the other risks get signed off by the team. Regarding the unmitigated risks, they are still on the risk list. This list constitutes an input to the next iteration.

As a final remark, SVT-I is in the process of scaling up the agile project with more teams. This implies greater communication burden among the teams, the various process levels and the *AF*. Regarding the communication among the teams, the organization is in the process of creating daily inter-team meetings corresponding to the *Scrum of Scrum* meetings [13]. During these meetings, the team leaders discuss status of their teams. If any major risks are identified, then they are reported to the *AF*.

V. EVALUATION RESULTS

In this section, we present the evaluation results. It is structured according the three requirements: the integration model, integrated model and the aspect of agility.

A. Integration Model

The majority of the interviewees stated that the integration model provided practical guidance on how to integrate risk management and agile development processes.

Regarding the integration model, all the ten interviewees agreed that the four components were relevant and useful for integration. In their opinion, they identified the basic points of integration. None of them missed any points.

1) Organizational Levels and Process Phases

Overall, all the interviewees considered the *Organizational Levels and Process Phases* component a highly relevant integration point. The mapping of risk management in the agile process is useful to find out when and where risk management takes place. The interviewees were particularly positive about the fact that we made risk management explicit on an organization-wide basis.

2) Roles and Responsibilities

Overall, the interview results show evidence that the *Roles and Responsibilities* component comprises a valid integration point. The majority of the interviewees confirmed the need to identify the various roles responsible for managing risks. In this way, one may ensure that risks are managed effectively. It was also considered positive that we had not detailed the roles since they varied within different organizations.

3) Communication Channels

The role of *Communication Channels* raised most concern. However, more than half of the interviewees agreed with their function and verified their importance, while the other half was more reserved about their applicability in an agile context. The positive half stated that the channels were useful and relevant for integration as they defined the flow of risk communication throughout the organization. They ensure that risks are communicated in an organized way, and most importantly, that risk

communication takes place. In addition, their establishment provides structure to the process allowing analysis of how to make it more cost effective, which is considered particularly important in larger organizations.

The other interviewees were clearly negative about the use of the channels. The reason was that they conflicted with one of the fundamental ideas of agile development, that is, enabling collaboration and allowing people to be able to talk to anybody, whenever needed. Several of these interviewees also stated that in order for the *Communication Channels* to be useful, they would like to have more concrete suggestions and guidelines for how the communication of risks should take place in an agile way, for instance via Wikis or Story Walls.

4) Process Aspects

All of the interviewees confirmed that the *Process Aspects* was a valid component of the integration model. They determined the need for risk management and they were useful for tailoring the process according to the needs identified in the specific context at hand. They were considered to constitute useful checklist items. However, it was also claimed that it was unclear how we intended each aspect to be used and how it would eventually impact the design of the integrated process. For this reason, it was suggested that our proposal included practical examples.

B. Integrated Model

Concerning the integrated model, all of the interviewees agreed that it provided a useful reference model against which they could compare notes. In addition, making risk management explicit on an organization-wide level raises the important issue of managing risks, which is sometimes down prioritized, neglected or even forgotten.

The major criticism was that the integrated model did not allow one to compare *how* risk management was conducted. It only depicted *when*, *where* and by *whom* the process was performed. In this respect, its usefulness was considered limited to process engineers, business developers or any other roles involved in designing or improving processes. The interviewees representing developers or other process executors did not find it very useful. Instead, they requested concrete guidelines for *how* to conduct risk management in an agile way. For instance, by introducing activities such as automated risk sign-offs in acceptance testing or analysis of risk management in the retrospective meeting at the end of each iteration.

Another common criticism was that the integrated model conflicted with several agile principles, thus compromising agility. These conflicts primarily concerned the *RMF* and the *Roles and Responsibilities* integration point.

Regarding the *RMF*, the majority of the respondents stated that it was too authoritative for agile development. It was also questioned whether it would be applicable in small agile projects. Concerning the constellation of the *RMF*, several interviewees stated that it consisted of only a

specific selection of people or roles, excluding certain team members and project stakeholders. It was argued that this directly conflicted with the agile principles of collaboration and customer involvement. For these reasons, it was suggested that the function of the *RMF* was modified. Rather than referring to it as a group of people only, it could take the form of either a tool or a group of people, or both depending on the needs of various organizations.

In terms of a tool, it was suggested that the forum would take the form of a repository, such as a Wiki, that could be used for the organization-wide dissemination of risk information to be accessible on a daily basis. In terms of a group, it was proposed that the forum would be open for anyone concerned with the management of risks. Hence, we should remove any specification of roles for the *RMF*. Instead, it was proposed that the roles concerned with the risks at hand would gather on an incident-driven basis.

Concerns were also raised by some interviewees who did not agree with the *Roles and Responsibilities* that we had suggested in the integrated model. In their opinion, the delegation of risk management to certain roles in the organization makes the integrated process too static. To resolve this, it was suggested that we re-emphasized the fact that it was the team that shared responsibility for managing risks in agile development instead. This would better comply with the agile principles. Hence, we should make this explicit by removing all the roles and responsibilities as prescribed in the outline of the integrated model.

Finally, there was one aspect considered to be particularly important by all of the interviewees. It was that the integrated model was described as an organization-wide process. This was something that none of the interviewees had seen before. Hence, it was regarded a very important contribution. Moreover, several interviewees also liked the fact that it was illustrated on a phase level giving a quick and useful overview of the integration of the two processes.

C. Maintaining Agility

Overall, the majority of the interviewees, although representing the agile community, stated that our solution maintained agility. This was primarily because we did not change the agile process itself, but only added risk management on top of the agile base. In addition, it was also stated to be of importance that the guidelines were general allowing an organization to adapt risk management in its own way. However, some concerns were raised.

Adding anything to the agile process must be well motivated for. One needs to be very careful with adding things in order not to lose agility, especially since it is often done in competition with many other important development activities. Hence, it was suggested that we clarified the problem with risk management and identified when it should be added to the agile process.

On the other hand, it was also claimed by the majority of the interviewees that risk management actually was a very

important activity. Risks should be managed in all projects, at least in their organizations. Hence, our proposal for extending the risk management capability of the agile model was considered to be highly relevant for them.

Finally, it was stated by several interviewees that the degree of agility differed between projects depending on factors such as project size, complexity and type of development. It was suggested that it would be useful if we clarified the type of projects that our solution primarily concerned. In this way, one would know when it was useful.

VI. CONCLUSIONS

Generally, our evaluation results show that all the three requirements are fulfilled. Hence, we conclude that, within the scope of this research, integrating risk management and agile development provides a valid solution to address the lack of risk management in the agile model. However, our solution is considered valid only under circumstances where the inherent risk-driven nature of the agile development model is insufficient.

The need of risk management depends on several factors, such as project size, type of development, product complexity and overall project risk profile. More specifically, the results show that the integration of risk management adds most value in agile development contexts with one or several of the following characteristics: (1) teams consisting of more than ten people, (2) distributed teams, (3) development of safety critical, security critical, embedded systems, complex systems, entirely new systems and/or innovative systems, (4) projects with high risk exposure, e.g. depending on factors such as the external environment, organization, product status, technology, schedule, and so forth.

The integration of risk management was not considered necessary in smaller projects developing simple software where the team was co-located. In these cases, it was argued that the inherent risk-driven nature of the agile process itself allowed effective management of risks without adding risk management to it. Below, we discuss the results of each of the three requirements, starting with the integration model.

A. Integration Model

Regarding the proposed integration model, the interviewees agreed that it provided practical guidance for how to conduct integration. The four integration points were also considered relevant and useful. Hence, we do not modify the integration model. However, some concerns were raised regarding the usefulness of *Communication Channels*. Defining the flow of risk communication between various parts of the organization was not considered very useful unless guidelines for how to communicate risks in an agile way were provided. We consider this a very important feedback for extending our model.

A similar comment concerns the *Process Aspects* integration point. Several interviewees requested that our

proposal should include practical examples of its impact on the integrated process as well guidance on how to use them in the design process. We consider this a very important feedback for extending our model.

B. Integrated Model

The integrated model was considered to fulfill its purpose as a reference model. It was regarded useful for anybody interested in comparing their risk management practice. However, without providing guidelines on *how* to actually conduct agile risk management, its utility was considered limited. Hence, it was suggested that the integrated model was extended with guidelines on *how* to conduct agile risk management. This is also a very important advice for improving the model.

Some other concerns raised involved the *RMF* function and the roles in the integrated model. They were considered to conflict with agile principles. We consider this feedback highly relevant. However, we do not modify our model due to this observation. We believe that they should be an option and not a must, as far as other forms of achieving good communication, collaboration and shared project responsibility for risk management on a continuous, organization-wide basis are practiced. For instance, the *RMF* could be part of already existing cross-organizational functions in an organization such as the *Integrating Scrums* as suggested by [13].

C. Maintaining Agility

Our model provides a solution for extending the risk management capability of the agile model without changing the agile spirit. It also provides a simple tool for integrating the risk management process according to the needs at hand and a reference model for comparing notes. For these reasons, the interviewees agreed that agility would be maintained. However, it was also suggested how agility could be further enforced. For instance, it was proposed that any direct conflicts with agile principles, such as collaboration, were removed or further motivated. The reason argued was that adding any activities to the agile process must always be clearly justified.

In response to these comments, we wish to emphasize that none of the current agile models explicitly describes how to extend the agile model with risk management, or other processes. To fill in this gap, we therefore keep our model as originally described until other solutions are provided. We also lay emphasis on the fact that the model is tailorable to allow the user to maintain any degree of agility. In addition, we clarify that the model is not aimed at all projects. The projects and organizations primarily concerned by our solution are those with the characteristics listed above, such as projects with distributed teams or projects developing complex software, or projects which need to extend the risk management capability of their agile models for any other reasons not detected herein.

VII. EPILOGUE

In this paper, we have outlined a model integrating risk management and agile software development. The proposed solution consists of an integration model and an integrated model. It is primarily targeted towards process engineers and business developers or other groups involved in process engineering and improvement.

We have evaluated it in interviews with ten agile practitioners in the Swedish software industry. Based on the results, we can draw three main conclusions, (a) it is a valid solution for addressing the current lack of risk management in agile development, however only in certain projects and organizations, (b) the model needs to be further elaborated in terms of the guidance it provides, and (c) it needs be further investigated in terms of its applicability in practice.

ACKNOWLEDGMENT

We would like to thank SVT-I and the ten interviewees for providing the empirical foundation to this research. Thanks also Prof. Paul Johannesson, KTH, for valuable feedback.

REFERENCES

- [1] Armenta A.L and Gaono A., A Proposal of a Process Integration Model for Agile Software Development and Risk Management. Master Thesis, DSV, Stockholm University/KTH, Stockholm, Sweden, 2008.
- [2] Beck K., *Extreme Programming Explained: Embrace Change*. 2nd Ed. Upper Saddle River, NJ, Addison-Wesley, 2004.
- [3] Boehm et al., "Spiral Development of Software-Intensive Systems of Systems". Proc. of International Conference on Software Engineering, USA, 2005.
- [4] Cockburn A., *Crystal Clear: A Human-Powered Methodology for Small Teams*. Upper Saddle River, NJ, Pearson Education, 2005.
- [5] Englund H., "A Case Study to Explore Risk Management Models", Master's Thesis, Royal Institute of Technology, Sweden, 1997.
- [6] IEEE 1540 *Standard for Lifecycle Processes - Risk Management*. Institute of Electrical and Electronics Engineers Inc., NY, 2001.
- [7] Nyfjord J. and Kajko-Mattsson M., "Commonalities in Risk Management and Agile Process Models". Proc. of 2nd International Conference on Software Engineering Advances, France, 2007.
- [8] Nyfjord and Kajko-Mattsson, "Degree of Agility in Pre-Implementation Process Phases". Proc. of International Conference on Software Process, Germany, 2008.
- [9] Nyfjord and Kajko-Mattsson, "Agile Implementation Phase in Two Canadian Organizations". Proc. of 19th Australian Software Engineering Conference, Perth, Australia, 2008.
- [10] Nyfjord and Kajko-Mattsson, "Software Risk Management: Practice Contra Standard Models". Proc. of 2nd Conference on Research Challenges in Information Systems, Morocco, 2008.
- [11] Nyfjord J. and Kajko-Mattsson M., "Integrating Risk Management with Software Development: State of Practice". Proc. of IAENG International Conference on Software Engineering, China, 2008.
- [12] Project Management Institute, "A Guide to the Project Management Body of Knowledge" (PMBOK). 3rd Ed. ANSI/PMI 99-001-2004, PMI, 2004.
- [13] Schwaber K., *The Enterprise and Scrum*. Redmond, WA, Microsoft Press, 2007.
- [14] Sliger M., "Relating PMBoK Practices to Agile Practices" (Part 3 of 4). URL: <http://www.stickyminds.com/sitewide.asp?Function=edetail&ObjectType=COL&ObjectId=11133&commex=1#4993>.